

INFORME DE AUDITORIA TECNICA

Auditoría Terraform AWS

Infraestructura como Código

FECHA DE AUDITORIA

2026-07-06

PROYECTO

Portal de Créditos

AUTOR

Infraestructura MOA (auditoría asistida)

1. Resumen ejecutivo

Portal de Créditos es una aplicación interna (uso restringido por VPN/red corporativa) compuesta por dos servicios independientes sobre **AWS ECS Fargate**: un backend ASP.NET Core + Flyway (`infra/terraform/backend/`) y un frontend Angular servido por Nginx (`infra/terraform/frontend/`). Cada servicio es un stack Terraform independiente, modularizado (`ecr` , `ecs` , `iam` , `monitoring` , `networking`), orquestado por Azure DevOps (`azure-pipelines-iac.yml`).

La arquitectura de código **replica correctamente el patrón central de la propuesta v3.3** aprobada por el proveedor (Frontend Angular en ECS/Fargate detrás de un Internal ALB, Backend .NET en ECS/Fargate, sin exposición pública directa, sin Cognito, secretos vía Secrets Manager). Sobre ese acierto arquitectónico de fondo, la auditoría identifica **10 hallazgos** (serie H) y **5 desvíos de conformidad** (serie C) que deben resolverse o quedar formalmente aceptados por Infraestructura MOA antes del primer despliegue productivo.

El repositorio incluye documentación extensa del propio proveedor, incluyendo autoevaluaciones en `docs/audits/` que se autocalifican con "97% de cumplimiento" y "sin deuda técnica". Estas autoevaluaciones **no sustituyen esta auditoría** ni son fuente de definiciones válidas: se tratan como comentarios de referencia del proveedor; las definiciones clave (tags, alcance arquitectónico, criticidad) son las de Infraestructura MOA. Varias afirmaciones del proveedor no se sostienen contra el código real (ver H-002, H-004, H-010 y la serie C), en línea con el principio de no confiar en la documentación del proveedor.

Métrica	Cantidad
Hallazgos activos (serie H)	10
Desvíos de conformidad (serie C)	5
Crítica	1
Alta	2
Media	4
Baja	9

Conclusiones clave:

- **Autenticación del pipeline:** usa Access Keys IAM estáticas en un Variable Group de Azure DevOps en vez de Service Connection — incumplimiento directo del estándar (H-001, Alta).
- **Exposición a Internet:** correcta por diseño — ambos ALB son internos por defecto (`load_balancer_internal = true`) y restringidos a `10.0.0.0/8` . No hay exposición pública directa de frontend, backend, ni de las subredes de tareas ECS.

- **TLS en tránsito:** no está forzado por diseño; si no se provee `certificate_arn`, ambos ALB sirven HTTP puro (C-001, Desvío Alta). HTTPS con certificado ACM es obligatorio, sin excepción, en todos los ambientes.
- **Base de datos fuera del código:** Amazon RDS for PostgreSQL, componente obligatorio de la propuesta, no está provisionado por ningún stack Terraform del repositorio. El proveedor lo documentó como "pre-existente / fuera de alcance"; esa exclusión no se acepta — la solución debe contemplar el aprovisionamiento de RDS (**C-005, Crítica**).
- **Alcance incompleto frente a la propuesta:** el repositorio tampoco provisiona el **S3 documental privado** que la propuesta exige para que la aplicación web guarde y consulte sustentos/evidencias de crédito (C-004, Desvío Alta).
- **IA:** no se detectó SDK ni modelo de IA en el código auditado.
- **Secretos:** sin hallazgos de secretos en texto plano; el uso de ARNs de Secrets Manager con `sensitive = true` es consistente (con una excepción menor, H-010).
- **Tags obligatorios:** Infraestructura MOA definió los valores oficiales de los tags obligatorios (ver §10). El más relevante: `Application = "Gestion-Crediticia"`. Verificado contra `env/qa.tfvars` (backend y frontend, agregados por el proveedor): el tag `Application` sigue con `"Portal-Creditos"`, que no coincide con el valor oficial ni con ningún valor del enum corporativo (H-005).
- `env/qa.tfvars` **reales agregados por el proveedor:** cubren QA para backend y frontend (mejora parcial de H-009), pero **no resuelven H-004:** `terraform fmt -check` sigue fallando en `locals.tf` / `main.tf` de ambos stacks, y los propios `env/qa.tfvars` nuevos introducen drift de formato adicional.

2. Tabla ejecutiva de hallazgos (serie H)

ID	Hallazgo	Criticidad	Estado	Riesgo	Sección guía
H-001	Autenticación AWS del pipeline con Access Keys estáticas, no Service Connection	Alta	Nuevo	Credenciales de larga duración en un Variable Group; incumple el estándar de autenticación federada	§13
H-002	<code>variables.tf</code> (raíz, ambos stacks) declara <code>default</code> en la mayoría de sus variables	Media	Nuevo	Valores no confirmados por MOA pueden desplegarse sin que el <code>.tfvars</code> los sobreescriba explícitamente	§12
H-003	Sin gate de aprobación explícito entre <code>plan</code> y <code>apply</code> en el pipeline	Media	Nuevo	<code>apply -auto-approve</code> puede ejecutarse sin revisión humana visible en el repositorio	§13
H-004	<code>terraform fmt -check</code> falla en ambos stacks (drift de formato)	Baja	Nuevo — persiste; se agregaron <code>env/qa.tfvars</code> pero éstos también fallan <code>fmt -check</code>	El propio pipeline exige este gate; con el código actual fallaría antes de <code>plan</code>	§3

ID	Hallazgo	Criticidad	Estado	Riesgo	Sección guía
H-005	Tag <code>Application</code> fuera del enum corporativo. Infraestructura MOA definió el valor oficial (<code>"Gestion-Crediticia"</code>); el código/ <code>tfvars</code> real todavía usa <code>"Portal-Creditos"</code>	Baja	Nuevo	Rompe agrupación/reporting por <code>Application</code> en AWS Cost Explorer / Config	\$10
H-006	Excepciones de nomenclatura (EXC-01/02/03/05): el código usa el componente técnico (<code>API / WEB</code>) donde debería ir el valor del tag <code>Application</code> , y los nombres de ALB/Target Group no respetan el patrón MOA (mayúsculas + componente Aplicación)	Baja	Nuevo — patrones corregidos por Infraestructura MOA, código pendiente de actualizar	Nombres de recursos no siguen el patrón MOA confirmado; rompe trazabilidad/búsqueda por convención	\$11
H-007	Variable <code>public_subnet_ids</code> (backend) ambigua para un ALB interno por defecto	Baja	Nuevo	Riesgo de que un operador ubique el ALB en subredes verdaderamente públicas	\$11
H-008	Lock de estado vía DynamoDB; Infraestructura MOA exige migrar a <code>use_lockfile = true</code> (locking nativo S3) como buena práctica	Media	Nuevo	Requiere subir <code>required_version</code> a <code>>= 1.10 / 1.11</code> en ambos stacks; hoy fijado en <code>~> 1.8</code>	\$14
H-009	Sin <code>tfvars</code> de ejemplo específico para PRD con valores productivos	Baja	En proceso — QA ya cubierto (<code>env/qa.tfvars</code> backend y frontend); PRD sigue sin equivalente	Riesgo de desplegar PRD con valores pensados para QA (<code>desired_count</code> , <code>alb_deletion_protection</code>)	\$12
H-010	<code>task_role_policy_json</code> sin <code>sensitive = true</code> (backend y frontend)	Baja	Nuevo	Puede contener ARNs/recursos internos sensibles expuestos en plan/logs	\$12

3. Resumen técnico

Archivos analizados: los 6 archivos raíz (`main.tf` , `providers.tf` , `variables.tf` , `locals.tf` , `outputs.tf` , `versions.tf`) y los 5 módulos locales (`ecr` , `ecs` , `iam` , `monitoring` , `networking` , cada uno con `main.tf` / `variables.tf` / `outputs.tf`) de **ambos** stacks (`infra/terraform/backend/` , `infra/terraform/frontend/`); archivos de ejemplo (`*.tfvars.example` , `backend*.hcl.example` , `env/qa.tfvars.example`); `azure-pipelines-iac.yml` ; `README.md` (raíz , backend , frontend); `docs/01-Architecture.md` , `docs/02-Deployment-Inputs.md` , `docs/05-Exceptions.md` ; y los documentos del proveedor en `docs/audits/*.md` (tratados como autoevaluación, no como fuente de verdad). Documento de propuesta aprobada: `Propuesta_Arquitectura_AWS_Portal_Creditos_v3.3_Frontend_ECS.docx` y `Resumen_Costos_AWS_Portal_Creditos_v3.3_Frontend_ECS_SingleAZ.docx` (ambos con diagramas de arquitectura embebidos, inspeccionados visualmente).

Providers: `hashicorp/aws` `~> 5.0` (versión resuelta en `.terraform.lock.hcl` : `5.100.0`) en ambos stacks. Sin providers adicionales, sin módulos remotos.

Módulos: `modules/ecr` , `modules/ecs` , `modules/iam` , `modules/monitoring` , `modules/networking` — todos locales, en `./modules/` , invocados desde `main.tf` raíz. El root module no declara recursos directamente (correcto).

Servicios AWS: ver §6.

Backend Terraform (estado remoto): S3 con `encrypt = true` y lock vía `dynamodb_table` (no `use_lockfile` ; ver H-008). Bucket referencial `moaplatformiac-apps-prd-tfstate` compartido entre ambos stacks, con `key` distinta por stack/ambiente. Archivos `backend*.hcl` reales están en `.gitignore` (correcto).

Autenticación: el pipeline usa `AWS_ACCESS_KEY_ID` / `AWS_SECRET_ACCESS_KEY` desde un Variable Group de Azure DevOps — **no** usa Service Connection (H-001). No se detectó `profile` ni `aws_profile` en `providers.tf` / `variables.tf` (correcto en el código Terraform en sí; el problema está en la capa de pipeline).

Validación sintáctica ejecutada en esta auditoría (sin contactar backend remoto, sin `apply` / `destroy` / `import`):

```
terraform fmt -check -recursive -diff  → FALLA en ambos stacks (ver H-004)
terraform init -backend=false           → OK en ambos stacks
terraform validate                       → OK en ambos stacks ("Success! The configuration is valid.")
```

Principales riesgos técnicos: autenticación no federada del pipeline (H-001); TLS no forzado por diseño (C-001); ausencia de aprobación explícita entre plan y apply (H-003); componente de almacenamiento documental de la propuesta no cubierto por el código ni por la documentación de alcance (C-004).

4. Tabla técnica de hallazgos (serie H)

ID	Hallazgo	Corrección recomendada
H-001	<code>azure-pipelines-iac.yml</code> inyecta <code>AWS_ACCESS_KEY_ID</code> / <code>AWS_SECRET_ACCESS_KEY</code> desde el Variable Group <code>portal-creditos-iac-{qa,prod}</code> en el paso <code>env</code> : de cada job Terraform (líneas ~248-250 y ~344-345).	Sustituir por una Service Connection AWS gestionada por MOA (OIDC / role federation) para las operaciones <code>plan</code> y <code>apply</code> . Retirar <code>AWS_ACCESS_KEY_ID</code> / <code>AWS_SECRET_ACCESS_KEY</code> del Variable Group.
H-002	<code>variables.tf</code> raíz de ambos stacks declara <code>default</code> en la mayoría de sus variables no obligatorias: <code>aws_region="us-east-1"</code> , <code>environment="qa"</code> , los 8 <code>tag_*</code> (<code>tag_application</code> , <code>tag_area</code> , <code>tag_risk</code> , <code>tag_backup_policy</code> , <code>tag_environment</code> , <code>tag_autopowerson</code> , <code>tag_autopoweroff</code>), <code>task_cpu</code> , <code>task_memory</code> , <code>container_port</code> , <code>log_retention_days</code> , <code>ecr_image_tag_mutability</code> , <code>cpu_architecture</code> , <code>autoscaling_enabled</code> , entre otras. El estándar de referencia de esta auditoría exige que <code>variables.tf</code> no lleve <code>default</code> y que los valores vivan únicamente en <code>terraform.tfvars</code> .	Quitar los <code>default</code> de las variables cuyo valor deba ser confirmado por MOA por ambiente (tags, sizing, red) y moverlos a <code>terraform.tfvars</code> / <code>env/<amb>.tfvars</code> . Mantener sin <code>default</code> únicamente lo que ya no lo tiene (<code>vpc_id</code> , ARNs de secretos, <code>tag_costcenter</code>), que sí cumple.

ID	Hallazgo	Corrección recomendada
H-003	El job deployment: iac ejecuta terraform plan -out=tfplan y, si terraformAction=apply, inmediatamente terraform apply -auto-approve tfplan en el mismo step/job (líneas 239-246 backend, 334-341 frontend). No hay un stage de solo lectura que publique el tfplan como artefacto para revisión previa a la aprobación.	Separar plan y apply en stages distintos; publicar el plan como artefacto; condicionar el apply a la aprobación del environment de Azure DevOps, y confirmar/documentar que dichos approval gates están efectivamente configurados (no son visibles desde el YAML).
H-004	terraform fmt -check -recursive -diff falla en infra/terraform/backend (locals.tf , main.tf) y en infra/terraform/frontend (locals.tf , main.tf) por desalineación de columnas en bloques de asignación. Re-verificado tras el agregado de env/qa.tfvars : el drift original persiste sin cambios , y los nuevos env/qa.tfvars de ambos stacks agregan su propio drift (aws_region / project_name / environment en backend; min_capacity / max_capacity en ambos).	Ejecutar terraform fmt -recursive sobre ambos stacks (incluyendo los env/*.tfvars reales, no solo los .tf) y commitear el resultado antes de que el pipeline vuelva a correr el gate terraform fmt -check .
H-005	variables.tf (ambos stacks): tag_application por defecto es "Portal-Creditos", idéntico al valor de tag_project . El catálogo de valores de Application (references/tags.md) no incluye "Portal-Creditos". El valor oficial definido por Infraestructura MOA es Application = "Gestion-Crediticia" . Verificado contra env/qa.tfvars (backend y frontend, agregados por el proveedor): ambos siguen con tag_application = "Portal-Creditos" .	Actualizar tag_application = "Gestion-Crediticia" en env/qa.tfvars de backend y frontend (y en cualquier tfvars de PRD que se cree, ver H-009), y agregar "Gestion-Crediticia" al catálogo corporativo de valores de Application si aún no existe formalmente.
H-006	docs/05-Exceptions.md documenta EXC-01 (ECR lowercase), EXC-02 (ALB/TG sin componente Aplicación, límite 32 caracteres), EXC-03 (SG adaptado EC2→ECS) y EXC-05 (Log Group adaptado EC2→ECS), las cuatro marcadas " ⚠ PENDIENTE DE APROBACIÓN ESCRITA POR MOA". El mismo texto se repite como comentario en locals.tf de ambos stacks ("EXCEPTION AGREED WITH MOA... Pending formal written confirmation"), lo cual es contradictorio en sí mismo. Causa raíz más profunda: en las cuatro excepciones, el código usa application_name / service_name ("api" / "web" , un identificador técnico de componente) donde el patrón MOA espera el valor del tag Application ("Gestion-Crediticia" , confirmado por MOA — ver H-005). tag_application no se usa en ningún nombre de recurso del repositorio, solo en el tag. Infraestructura MOA definió y verificó en esta auditoría los patrones corregidos (ver §11), que ya contemplan ambos datos: Application (abreviado GEST) y el componente técnico (API / WEB) para distinguir backend de frontend.	Actualizar locals.tf de ambos stacks para calcular standard_application_name a partir de var.tag_application (abreviado GEST para las familias con límite de caracteres) en vez de var.application_name / var.service_name , agregando el componente técnico (API / WEB) como un campo adicional del patrón, no como reemplazo. Aplicar los nombres exactos confirmados en §11. Corregir el comentario en locals.tf para no afirmar un acuerdo que aún no existe.
H-007	infra/terraform/backend/variables.tf : public_subnet_ids — "Public subnet IDs for the Application Load Balancer." El ALB backend es interno por defecto (load_balancer_internal = true), por lo que en el uso esperado esta variable debe recibir subredes privadas/internas, no públicas. El propio README del stack ya lo aclara ("Subnets Públicas / Internas (ALB)"), pero el nombre de la variable no.	Renombrar a alb_subnet_ids (como ya se hace en el módulo networking y en el stack frontend, que usa load_balancer_subnet_ids) para eliminar la ambigüedad, o documentar explícitamente en la descripción de la variable que debe recibir subredes internas cuando load_balancer_internal = true .

ID	Hallazgo	Corrección recomendada
H-008	<code>backend*.s3.hcl.example</code> / <code>backend*.hcl.example</code> configuran <code>dynamodb_table = "moaplatformiac-terraform-locks"</code> para locking, en vez de <code>use_lockfile = true</code> (locking nativo S3). Infraestructura MOA exige migrar a S3 con locking nativo como buena práctica, en vez de DynamoDB.	Migrar <code>backend*.s3.hcl</code> / <code>backend*.hcl</code> (todos los ambientes, ambos stacks) a <code>use_lockfile = true</code> , retirando <code>dynamodb_table</code> . Requiere subir <code>required_version</code> a <code>>= 1.10</code> (o <code>1.11</code>) en <code>versions.tf</code> de ambos stacks — hoy fijado en <code>~> 1.8</code> , versión que no soporta <code>use_lockfile</code> . Planificar como tarea de actualización de versión antes de aplicar el cambio de backend.
H-009	Existen <code>backend.prd.s3.hcl.example</code> / <code>backend.prd.hcl.example</code> (config de estado) pero no existe un <code>env/prd.tfvars</code> (ni <code>.example</code>) con valores productivos recomendados (<code>desired_count=2</code> , <code>alb_deletion_protection=true</code> , etc.). El proveedor agregó <code>env/qa.tfvars</code> reales para backend y frontend en esta iteración — QA queda cubierto — pero PRD sigue sin archivo equivalente.	Agregar <code>env/prd.tfvars</code> (backend) y un ejemplo equivalente para frontend, con los valores que la propuesta y las buenas prácticas recomiendan para producción (incluyendo <code>certificate_arn</code> obligatorio — ver C-001 — y <code>tag_risk</code> / <code>tag_application</code> con los valores oficiales confirmados por MOA).
H-010	<code>variables.tf</code> (ambos stacks): <code>task_role_policy_json</code> no declara <code>sensitive = true</code> , a diferencia del resto de variables que referencian ARNs/políticas (<code>postgres_connection_string_secret_arn</code> , <code>jwt_signing_key_secret_arn</code> , etc., que sí lo declaran consistentemente).	Agregar <code>sensitive = true</code> a <code>task_role_policy_json</code> en <code>infra/terraform/backend/variables.tf</code> e <code>infra/terraform/frontend/variables.tf</code> .

5. Matriz de conformidad arquitectónica (serie C)

Comparación contra `Propuesta_Arquitectura_AWS_Portal_Creditos_v3.3_Frontend_ECS.docx` (arquitectura recomendada, Figura 1: VPN/red corporativa → Internal ALB → ECS Fargate Angular+Nginx / ECS Fargate API .NET → RDS PostgreSQL privado + S3 documental privado + Secrets/KMS/CloudWatch) y `Resumen_Costos_AWS_Portal_Creditos_v3.3_Frontend_ECS_SingleAZ.docx`.

ID	Componente / definición	En propuesta	En código	Estado	Acción recomendada
—	Frontend Angular en ECS Fargate + Nginx detrás de Internal ALB	Sí	Sí	Conforme	—
—	Backend .NET/ASP.NET Core en ECS Fargate detrás de Internal ALB	Sí	Sí	Conforme	—

ID	Componente / definición	En propuesta	En código	Estado	Acción recomendada
—	Portal sin exposición pública directa (ALB interno, SG restringidos a red interna)	Sí	Sí	Conforme	—
—	Sin AWS Cognito; identidad vía Microsoft Entra ID (fuera del alcance de Terraform)	Sí	Sí	Conforme	—
—	Secretos vía Secrets Manager/Parameter Store, sin credenciales en texto plano	Sí	Sí	Conforme	—
—	ECR + Azure DevOps + Terraform CI/CD para backend y frontend	Sí	Sí	Conforme	—
—	Dimensionamiento frontend: 1 tarea, 0.25 vCPU / 0.5 GB	Sí	Sí (<code>task_cpu=256</code> , <code>task_memory=512</code>)	Conforme	—
C-001	Cifrado TLS en tránsito (Sección 8 de la propuesta: control de seguridad obligatorio)	Sí	Parcial — <code>certificate_arn</code> es opcional; sin valor, ambos ALB sirven solo HTTP	Desvío (Alta)	HTTPS con certificado ACM es obligatorio, sin excepción, en todos los ambientes (no solo PRD). Exigir <code>certificate_arn</code> no vacío antes de cualquier <code>apply</code> ; bloquear el <code>apply</code> si está vacío. Confirmar con MOA Seguridad el certificado ACM a usar.
C-002	Retención de CloudWatch Logs: 7 días (Sección 3 y 6 de la propuesta)	Sí	<code>log_retention_days = 30</code> por defecto y en <code>.tfvars.example</code> (ambos stacks)	Desvío (Media)	Ajustar el default/ <code>.tfvars</code> a 7 días, o confirmar con MOA si 30 días es el valor corporativo real y actualizar la propuesta para reflejarlo (impacto: mayor costo de almacenamiento, no es un riesgo de seguridad).
C-003	Backend API: 2 tareas ECS Fargate para redundancia básica (Sección 7 de la propuesta)	Sí	<code>desired_count = 1</code> por defecto (<code>variables.tf</code> , <code>terraform.tfvars.example</code> , <code>env/qa.tfvars</code>); autoscaling permite escalar a 2 bajo carga (<code>max_capacity=2</code>) pero la base no arranca en 2	Desvío (Media)	Confirmar si QA puede operar con 1 tarea base (aceptable por costo) pero exigir <code>desired_count = 2</code> en el <code>tfvars</code> de PRD, acorde a la propuesta. Ver también H-009 (falta de <code>tfvars</code> de PRD).

ID	Componente / definición	En propuesta	En código	Estado	Acción recomendada
C-004	Repositorio documental S3 privado para sustentos/evidencias de solicitudes de crédito, con lifecycle y cifrado (Secciones 5 y 7 de la propuesta)	Sí	No — ningún <code>aws_s3_bucket</code> en ninguno de los dos stacks, y el componente no figura en las tablas de "Recursos NO creados por Terraform" de <code>docs/01-Architecture.md</code> ni en <code>README.md</code> (a diferencia de RDS, que sí está explícitamente excluido y documentado)	Desvío (Alta)	Debe existir un bucket S3 privado desde el cual la aplicación web pueda guardar y consultar los documentos (no alcanza con almacenamiento pasivo). Definir con MOA si se provisiona en este repositorio (nuevo módulo <code>s3-documents</code> , con el acceso IAM correspondiente desde el task role del backend/frontend) o en otro stack, y documentarlo explícitamente como dependencia.
C-005	Amazon RDS for PostgreSQL (Single-AZ), base transaccional del backend (Secciones 3, 5 y 7 de la propuesta)	Sí	No — ningún <code>aws_db_instance</code> / <code>aws_rds_cluster</code> en el repositorio; el backend solo referencia por ARN un secret de Secrets Manager con la cadena de conexión, asumiendo una instancia ya existente administrada fuera de Terraform	Desvío (Crítica)	El proveedor documentó RDS como "pre-existente / fuera de alcance" en <code>docs/01-Architecture.md</code> y <code>README.md</code> ; esa exclusión no se acepta — la solución debe contemplar el aprovisionamiento de RDS. Definir con MOA si se agrega un módulo <code>rds</code> a <code>infra/terraform/backend/</code> (con subnet group privado, cifrado KMS, backups, Single-AZ/Multi-AZ según Sección 7 de la propuesta) o si se gestiona en un stack de datos separado, pero en cualquier caso debe quedar dentro del alcance de la entrega, no como dependencia externa no gestionada.

6. Servicios AWS identificados

Servicio	Uso	Público / Privado	Observaciones
Amazon ECS Fargate	Cómputo del backend API (.NET) y del frontend (Angular/Nginx)	Privado (subredes privadas, sin IP pública)	<code>assign_public_ip = false</code> por defecto en ambos stacks
Amazon ECR	Registro de imágenes Docker (API, Flyway, frontend)	Privado	Cifrado AES256, <code>scan_on_push=true</code> , <code>IMMUTABLE</code> por defecto
Elastic Load Balancing (ALB)	Entrada HTTP/HTTPS hacia frontend y backend	Interno por defecto (<code>load_balancer_internal=true</code>)	Configurable a público; ver C-001 sobre TLS
AWS IAM	Roles de ejecución y de tarea ECS	N/A	Roles separados execution/task, sin <code>Action="*" + Resource="*"</code>
Amazon CloudWatch Logs	Logs de contenedores (API, Flyway, frontend)	Privado	Retención 30 días (ver C-002); cifrado opcional vía KMS

Servicio	Uso	Público / Privado	Observaciones
AWS Application Auto Scaling	Escalado por CPU de los servicios ECS	N/A	Target tracking, <code>min=1</code> / <code>max=2</code> por defecto
AWS Secrets Manager / SSM Parameter Store	Secretos de backend (DB, JWT, Flyway, SAP, Motor Decisiones)	Privado	Consumido por ARN; no gestionado por este repositorio
Amazon RDS for PostgreSQL	Base transaccional del backend	Ausente del código — no gestionado por Terraform en este repositorio	No provisionado — C-005 (Crítica). El proveedor lo trata como pre-existente; esa exclusión no se acepta.

7. Componentes AWS creados

Nombre	Tipo	Servicio	Público / Privado	¿Vulnerable desde Internet?	URL	IP	Protección identificada
ALB-portal-creditos-QA	Load Balancer	ELB	Privado (default)	No, si se mantiene el default	<code>alb_dns_name</code> (interno)	—	SG restringido a <code>10.0.0.0/8</code> ; sin exposición si no se cambia <code>load_balancer_internal</code>
ALB-portal-creditos-web-QA	Load Balancer	ELB	Privado (siempre interno por diseño)	No	<code>alb_dns_name</code> (interno)	—	Igual que arriba
ECS-SVC-Portal-Creditos-API-QA	Servicio ECS Fargate	ECS	Privado	No (subred privada, sin IP pública)	—	—	SG de servicio solo acepta tráfico del SG del ALB en el puerto 8080
ECS-SVC-Portal-Creditos-WEB-QA	Servicio ECS Fargate	ECS	Privado	No	—	—	Igual que arriba
ecs-repo-portal-creditos-api-qa / -db-qa / -web-qa	Repositorio	ECR	Privado	No	—	—	Acceso vía IAM únicamente
SG_MOA_ECS_QA_Portal-Creditos-ALB / -API / -WEB-ALB / -WEB-SVC	Security Group	VPC	N/A	—	—	—	Ingress restringido según capa (ALB: <code>10.0.0.0/8</code> ; Servicio: solo desde SG del ALB)
ROLE-ECS-*--EXECUTION / -TASK	Rol IAM	IAM	N/A	—	—	—	Sin políticas de administrador; permisos acotados a ARNs de secretos referenciados

8. Evaluación de exposición a Internet

Ambos Application Load Balancer son **internos por defecto** (`load_balancer_internal = true`) y sus Security Groups de ingreso están restringidos a `10.0.0.0/8` por defecto — consistente con el requisito central de la propuesta ("aplicación interna sin publicación pública"). Ningún recurso ECS tiene IP pública (`assign_public_ip = false` por defecto) y las tareas siempre corren en subredes privadas. No se detectaron Security Groups con `ingress 0.0.0.0/0` , ni Function URLs, ni API Gateway público, ni S3 sin bloqueo de acceso público (no hay recursos S3 en este código; ver C-004).

El único punto débil de la postura de exposición no es la superficie pública sino el **cifrado en tránsito**: como ambos ALB pueden operar en HTTP puro si no se provee `certificate_arn` (ver C-001), el tráfico entre los clientes VPN y el ALB podría viajar sin TLS si MOA no completa esta variable antes del despliegue. Dado que el acceso ya está limitado a la red interna/VPN, el riesgo residual es menor que en un escenario de exposición pública, pero sigue siendo un incumplimiento del control de cifrado explícitamente exigido por la propuesta.

Conclusión: postura de red conforme a "interno por defecto"; pendiente forzar TLS (C-001) y confirmar los CIDR de VPN reales con MOA Networking/Seguridad antes de PRD.

9. Evaluación de uso de IA

Aspecto	Detalle
¿Se detectó uso de IA?	No, en el código Terraform auditado
Dónde se detectó	N/A — no hay SDKs, endpoints de modelos ni claves de API de IA en <code>infra/terraform/</code>
Proveedor / modelo	N/A
¿Homologada por MOA?	N/A
Riesgo asociado	Bajo, con una salvedad: <code>additional_environment / additional_secrets</code> del backend referencian una integración externa <code>MotorDecisiones</code> (<code>MotorDecisiones__ScoreApiUrl</code> , <code>MotorDecisiones__CallbackApiKey</code>) — un servicio de scoring/decisión cuya naturaleza (motor de reglas vs. modelo de IA) no es determinable desde este repositorio de infraestructura, ya que solo se inyecta como URL + API key.
Hallazgos relacionados	Ninguno formal. Se recomienda que el equipo de aplicación confirme si <code>MotorDecisiones</code> utiliza algún modelo de IA y, de ser así, si está homologado por MOA.

10. Validación de tags

Los 8 tags obligatorios más `Autopoweron / Autopoweroff` (opcionales, tratados como obligatorios por el proveedor) y `Costcenter` (obligatorio sin `default`, correcto) se aplican vía `default_tags` del provider en `local.common_tags`; `Name` se aplica por recurso con `tags = { Name = ... }`, que la capa `default_tags` fusiona automáticamente — patrón correcto según la regla de herencia.

Tags obligatorios y sus valores oficiales, según Infraestructura MOA (fuente de verdad para esta auditoría; los valores del proveedor en `variables.tf / env/qa.tfvars` son solo la implementación a verificar, no la definición): `Application = "Gestion-Crediticia"`, `Area = "Demanda"`, `Risk = "low"`, `Requester = "Fernando Ponce De Leon"`, `BackupPolicy = "NoBackup"`, `Environment = "QA"`, `Project = "Portal-Creditos"`.

Tag	Esperado (MOA)	En código real (<code>env/qa.tfvars</code> , ambos stacks)	Resultado
<code>Application</code>	"Gestion-Crediticia"	"Portal-Creditos"	✗ No coincide — H-005
<code>Name</code>	Por recurso, <code>merge(common_tags, {Name=...})</code>	<code>tags = {Name=...}</code> por recurso + herencia via <code>default_tags</code>	✓ Cumple
<code>Requester</code>	"Fernando Ponce De Leon"	"<MOA_REQUESTER>" (placeholder sin completar)	⚠ Formato correcto; valor real pendiente de completar
<code>Project</code>	"Portal-Creditos"	"Portal-Creditos"	✓ Cumple
<code>Environment</code>	"QA" (este archivo)	"QA" (con <code>validation block</code>)	✓ Cumple
<code>Risk</code>	"low"	<code>lower(var.tag_risk) = "medium"</code>	✗ No coincide
<code>Area</code>	"Demanda"	"Demanda"	✓ Cumple
<code>BackupPolicy</code>	Enum	"NoBackup" (con <code>validation</code> que solo acepta <code>NoBackup / DiarioR7</code>)	✓ Cumple
<code>Autopoweroff / Autopoweron</code>	Opcional, booleano	"false" / "false"	✓ Cumple
<code>Costcenter</code>	Opcional en el estándar; obligatorio en este código (sin <code>default</code> , <code>validation</code> no-vacío)	Pendiente de valor real de MOA Finanzas	✓ Cumple la regla de formato; valor real pendiente (bloqueante operacional, no de código)

Tag	Esperado (MOA)	En código real (<code>env/qa.tfvars</code> , ambos stacks)	Resultado
Recursos sin soporte de tags	<code>aws_iam_role_policy</code> , <code>aws_iam_role_policy_attachment</code> , <code>aws_ecr_lifecycle_policy</code>	Sin bloque <code>tags</code>	✓ No Aplica (correcto)
<code>aws_lb_listener</code> (x3 por stack)	Soporta tags en el proveedor AWS	Sin <code>Name</code> propio; hereda solo <code>common_tags</code> vía <code>default_tags</code>	i Observación menor — impacto mínimo, no se registra como hallazgo formal

11. Validación de nomenclatura

El código usa el componente técnico (`application_name / service_name` = "api" / "web") donde el patrón MOA espera el valor del tag `Application` ("Gestion-Crediticia"). Infraestructura MOA definió en esta auditoría la nomenclatura oficial para cada familia de recursos, incorporando ambos datos: el valor de `Application` y, cuando hace falta distinguir backend de frontend, el componente técnico como un campo adicional del patrón — **"{APP}"-"{COMPONENTE}"**, donde **{COMPONENTE} es API o WEB** — no como reemplazo de `Application`, sino sumado a él. La capitalización sigue la definida en el documento de mejores prácticas de MOA para cada familia (mayúsculas en general), salvo excepción cuando el propio servicio de AWS exige un formato distinto (ej. ECR y S3 exigen minúsculas).

Todos los nombres fueron verificados contra el límite real de caracteres de cada servicio de AWS (ver §3, validación ejecutada con `python /conteo exacto`, no manual). El más ajustado es IAM Role, con 55-56 de 64 caracteres.

Nomenclatura confirmada por Infraestructura MOA

Recurso	Nombre en código (actual)	Nombre confirmado por MOA
ECR — API	<code>ecs-repo-portal-creditos-api-qa</code>	<code>ecs-repo-portal-creditos-gestion-crediticia-api-qa</code>
ECR — WEB	<code>ecs-repo-portal-creditos-web-qa</code>	<code>ecs-repo-portal-creditos-gestion-crediticia-web-qa</code>
ECR — DB migraciones	<code>ecs-repo-portal-creditos-db-qa</code>	<code>ecs-repo-portal-creditos-gestion-crediticia-db-qa</code> (inferido: mismo patrón con Componente=DB, no confirmado explícitamente)
ALB — backend	<code>ALB-portal-creditos-QA</code>	<code>ALB-PORTAL-CRED-GEST-API-QA</code>
ALB — frontend	<code>ALB-portal-creditos-web-QA</code>	<code>ALB-PORTAL-CRED-GEST-WEB-QA</code>
Target Group — backend	<code>ALB-TG-portal-creditos-QA</code>	<code>ALB-TG-PORTAL-CRED-GEST-API-QA</code>

Recurso	Nombre en código (actual)	Nombre confirmado por MOA
Target Group — frontend	ALB-TG-portal-creditos-web-QA	ALB-TG-PORTAL-CRED-GEST-WEB-QA
Security Group servicio — backend	SG_MOA_ECS_QA_Portal-Creditos-API	SG_MOA_ECS_PORTAL_CREDITOS_GESTION_CREDITICIA_API_QA
Security Group servicio — frontend	SG_MOA_ECS_QA_Portal-Creditos-WEB-SVC	SG_MOA_ECS_PORTAL_CREDITOS_GESTION_CREDITICIA_WEB_QA
Security Group ALB — backend	SG_MOA_ECS_QA_Portal-Creditos-ALB	No definido — no se dio ejemplo; falta confirmar si lleva API / WEB para evitar nombre idéntico entre stacks
Security Group ALB — frontend	SG_MOA_ECS_QA_Portal-Creditos-WEB-ALB	No definido — idem
Log Group — API	/ecs/Portal-Creditos-QA/api	/ecs/PORTAL-CREDITOS-GESTION-CREDITICIA-QA/API
Log Group — WEB	/ecs/Portal-Creditos-QA/web	/ecs/PORTAL-CREDITOS-GESTION-CREDITICIA-QA/WEB
Log Group — Flyway/DB	/ecs/Portal-Creditos-QA/db-migrations	No definido — no se dio ejemplo
ECS Cluster — backend	ECS-CLT-Portal-Creditos-API-QA	ECS-CLT-PORTAL-CREDITOS-GESTION-CREDITICIA-API-QA
ECS Cluster — frontend	ECS-CLT-Portal-Creditos-WEB-QA	ECS-CLT-PORTAL-CREDITOS-GESTION-CREDITICIA-WEB-QA
ECS Service — backend	ECS-SVC-Portal-Creditos-API-QA	ECS-SVC-PORTAL-CREDITOS-GESTION-CREDITICIA-API-QA <i>(inferido, mismo patrón que ECS Cluster)</i>
ECS Service — frontend	ECS-SVC-Portal-Creditos-WEB-QA	ECS-SVC-PORTAL-CREDITOS-GESTION-CREDITICIA-WEB-QA <i>(inferido)</i>
ECS Task Definition — API	ECS-TASK-DEF-Portal-Creditos-API-QA	ECS-TASK-DEF-PORTAL-CREDITOS-GESTION-CREDITICIA-API-QA <i>(inferido)</i>
ECS Task Definition — WEB	ECS-TASK-DEF-Portal-Creditos-WEB-QA	ECS-TASK-DEF-PORTAL-CREDITOS-GESTION-CREDITICIA-WEB-QA <i>(inferido)</i>
ECS Task Definition — DB migraciones	ECS-TASK-DEF-Portal-Creditos-API-QA-DB	ECS-TASK-DEF-PORTAL-CREDITOS-GESTION-CREDITICIA-DB-QA <i>(inferido)</i>
IAM Role ejecución — backend	ROLE-ECS-Portal-Creditos-API-QA-EXECUTION	ROLE-ECS-PORTAL-CREDITOS-GESTION-CREDITICIA-API-EXEC-QA

Recurso	Nombre en código (actual)	Nombre confirmado por MOA
IAM Role tarea — backend	ROLE-ECS-Portal-Creditos-API-QA-TASK	ROLE-ECS-PORTAL-CREDITOS-GESTION-CREDITICIA-API-TASK-QA
IAM Role ejecución — frontend	ROLE-ECS-Portal-Creditos-WEB-QA-EXECUTION	ROLE-ECS-PORTAL-CREDITOS-GESTION-CREDITICIA-WEB-EXEC-QA
IAM Role tarea — frontend	ROLE-ECS-Portal-Creditos-WEB-QA-TASK	ROLE-ECS-PORTAL-CREDITOS-GESTION-CREDITICIA-WEB-TASK-QA
IAM Policy secrets — backend	POL-ECS-Portal-Creditos-API-QA-SECRETS	POL-ECS-PORTAL-CREDITOS-GESTION-CREDITICIA-API-SECRETS-QA <i>(inferido, mismo patrón que ROLE)</i>
Auto Scaling Policy — backend	AAS-Portal-Creditos-API-QA-CPU	AAS-PORTAL-CREDITOS-GESTION-CREDITICIA-API-CPU-QA
Auto Scaling Policy — frontend	AAS-Portal-Creditos-WEB-QA-CPU	AAS-PORTAL-CREDITOS-GESTION-CREDITICIA-WEB-CPU-QA

Filas marcadas *(inferido)*: siguen el mismo patrón que su recurso análogo ya confirmado, pero no fueron dadas como ejemplo explícito por Infraestructura MOA — quedan sujetas a confirmación antes de aplicarse como definición oficial. Filas marcadas **No definido**: no hay ejemplo ni inferencia segura posible (riesgo de colisión de nombre entre backend y frontend si se asume mal), no se completan sin confirmación.

Todos los valores fueron verificados dentro del límite de caracteres de su recurso AWS correspondiente (ECR 256, ALB/TG 32, Security Group 255, Log Group 512, ECS Cluster/Service/Task Definition 255, IAM Role 64, IAM Policy 128, Auto Scaling Policy 256).

12. Validación de variables y .tfvars

Control	Resultado	Evidencia	Observación
Código modularizado, root module solo orquesta módulos	✅ Cumple	main.tf de ambos stacks solo contiene bloques module	—
variables.tf (raíz y módulos) sin default	❌ No cumple (parcial)	Decenas de variables con default en variables.tf raíz de ambos stacks	H-002
Variables obligatorias sin default cuando corresponde	✅ Cumple	vpc_id, *_secret_arn, tag_costcenter sin default	—

Control	Resultado	Evidencia	Observación
Variables sensibles con <code>sensitive = true</code>	✅ Cumple (con 1 excepción)	7 variables de ARN en backend correctamente marcadas	<code>task_role_policy_json</code> no marcada — H-010
Todos los valores reales solo en <code>.tfvars</code> (no en <code>variables.tf</code>)	❌ No cumple (parcial)	Ver H-002	Mismo hallazgo que arriba
<code>.tfvars.example</code> documentado y no versionado como real	✅ Cumple	<code>.gitignore</code> excluye <code>*.tfvars</code> salvo <code>*.example</code>	—
<code>.tfvars</code> real por ambiente (QA/PRD)	⚠️ Parcial	<code>env/qa.tfvars</code> real agregado en esta iteración para backend y frontend; no existe equivalente PRD	H-009
Valores de tags en el <code>.tfvars</code> real coinciden con los valores oficiales de MOA	❌ No cumple	<code>env/qa.tfvars</code> (ambos stacks): <code>tag_application="Portal-Creditos"</code> (oficial: <code>"Gestion-Crediticia"</code>), <code>tag_risk="medium"</code> (oficial: <code>"low"</code>), <code>tag_requester="<MOA_REQUESTER>"</code> (placeholder sin completar)	H-005; ver §10

13. Providers y autenticación

El código Terraform en sí **no** usa `profile` ni la variable `aws_profile`, y no hay `access_key` / `secret_key` hardcodedos en `providers.tf` — correcto. El problema de autenticación está en la capa de pipeline: Azure DevOps ejecuta Terraform con `AWS_ACCESS_KEY_ID` / `AWS_SECRET_ACCESS_KEY` provistas como variables seguras de un Variable Group, en vez de una Service Connection AWS gestionada por MOA. No hay arquitectura multi-cuenta ni `assume_role` en este repositorio (una sola cuenta/región por ambiente), por lo que no aplica la distinción cross-account vs. Service Connection — solo aplica la autenticación de base, que no cumple.

Control	Resultado	Observación
Sin <code>profile</code> en provider "aws"	✅ Cumple	<code>providers.tf</code> de ambos stacks
Sin variable <code>aws_profile</code>	✅ Cumple	No existe en ningún <code>variables.tf</code>
Sin <code>access_key</code> / <code>secret_key</code> hardcodedas	✅ Cumple	No se encontraron valores hardcodedos
Autenticación del pipeline vía Service Connection (no Access Keys estáticas)	❌ No cumple	H-001
Cross-account con <code>assume_role</code> (no aplica en este repositorio)	N/A	Arquitectura de una sola cuenta por ambiente

14. Backend Terraform: tfstate y lock

Control	Resultado	Evidencia	Observación
Backend remoto activo (no comentado)	✅ Cumple	<code>backend "s3" {}</code> declarado (config externa vía <code>-backend-config</code>) en ambos stacks	—
<code>encrypt = true</code>	✅ Cumple	Presente en los 6 archivos <code>backend*.hcl.example</code>	—
Lock de estado	❌ No cumple	<code>dynamodb_table = "moaplatformiac-terraform-locks"</code> en vez de <code>use_lockfile = true</code>	H-008 — funcionalmente válido para <code>required_version = "~> 1.8"</code> , pero MOA exige migrar a locking nativo S3 (requiere subir a Terraform ≥ 1.10/1.11)
Bucket con versionado y bloqueo de acceso público	⚠️ No verificable desde este repositorio	Bucket confirmado por Infraestructura MOA: <code>moaplatformiac-data-analytics-qa-tfstate</code> (reemplaza el placeholder <code>moaplatformiac-apps-prd-tfstate</code> de <code>backend*.hcl.example</code>)	Confirmar con MOA Infraestructura que el bucket real tiene versionado y Public Access Block activos
Key del estado sin colisión entre stacks	✅ Resuelto — confirmado por Infraestructura MOA	Backend: <code>portal-creditos-gestion-crediticia-backend-qa/terraform.tfstate</code> . Frontend: <code>portal-creditos-gestion-crediticia-frontend-qa/terraform.tfstate</code> . A diferencia del resto de los recursos (que usan <code>API / WEB</code> como componente), acá el discriminador de stack es <code>backend / frontend</code> — verificado dentro del límite de 1024 caracteres de una key S3 (64 y 63 caracteres respectivamente)	El código actual usa un formato distinto (<code>portal-creditos-api/backend-qa.tfstate</code> / <code>portal-creditos-web/frontend-qa.tfstate</code>); corregir a los keys confirmados arriba en <code>backend*.hcl</code> / <code>backend*.s3.hcl</code> de ambos stacks

15. Revisión de outputs

Ningún output declara `sensitive = true` , pero **ninguno expone secretos, tokens ni claves**: los outputs son URLs (`alb_dns_name` , `api_url` , `frontend_url`), nombres/ARNs de recursos de infraestructura (`ecr_repository_url` , `ecs_cluster_name` , `service_security_group_id` , `task_definition_family` , `db_migrations_task_definition_arn`) — ninguno de estos valores es en sí mismo sensible. No se requiere `sensitive = true` en ellos.

16. Revisión IAM

- **Execution role:** solo `AmazonECSTaskExecutionRolePolicy` (managed) + política inline de Secrets Manager/SSM acotada a los ARNs efectivamente referenciados (`secret_arns`) — correcto, sin `Resource = "*"` para secretos.
- **Task role:** sin permisos por defecto; política custom opcional (`task_role_policy_json` , ver H-010) y política de ECS Exec opcional. Ambas son `count` -condicionadas (solo se crean si se habilitan explícitamente) — correcto, principio de mínimo privilegio por defecto.
- `ssmmessages:*` **con** `Resource = "*"` en la política de ECS Exec (ambos stacks, cuando `enable_execute_command = true`): esta familia de acciones de AWS Systems Manager no admite scoping por ARN de recurso individual — patrón aceptado, equivalente al caso de logging de Step Functions mencionado en la guía de referencia. Se registra como **nota**, no como hallazgo formal.
- **Trust policies:** acotadas a `ecs-tasks.amazonaws.com` únicamente, en ambos roles — correcto.
- No se encontró `Action = "*"` combinado con `Resource = "*"` en ninguna política del repositorio.

17. Conclusión

El código Terraform de Portal de Créditos implementa correctamente el patrón arquitectónico central de la propuesta v3.3 aprobada (frontend y backend en ECS Fargate detrás de un ALB interno, sin exposición pública, sin Cognito, secretos vía Secrets Manager) y muestra buenas prácticas consistentes de Terraform (modularización real, `lifecycle` apropiados, `deployment_circuit_breaker` , autoscaling, `prevent_destroy` en recursos críticos, variables sensibles casi siempre marcadas).

No se recomienda aprobar el despliegue a **PRD** hasta resolver, como mínimo: 1. **C-005 (Crítica)** — definir y provisionar Amazon RDS for PostgreSQL dentro del alcance de la solución; no se acepta que quede fuera del código. 2. **C-001 (Alta)** — forzar TLS en tránsito con certificado ACM, obligatorio sin excepción en todos los ambientes. 3. **C-004 (Alta)** — provisionar el S3 documental privado con acceso de lectura/escritura desde la aplicación web. 4. **H-001 (Alta)** — migrar la autenticación del pipeline a Service Connection. 5. **H-008 (Media)** — planificar la migración del lock de estado a `use_lockfile` (S3 nativo), lo que implica subir `required_version` a Terraform $\geq$ 1.10/1.11 en ambos stacks. 6. **H-003 (Media)** — confirmar/formalizar el gate de aprobación entre `plan` y `apply` . 7. **H-005** — aplicar en `env/qa.tfvars` (y en el futuro `env/prd.tfvars`) los valores oficiales de tags (`Application="Gestion-Crediticia"` , `Risk="low"` , `Requester` real en vez del placeholder `<MOA_REQUESTER>`).

Los hallazgos Media restantes (H-002) y Baja (H-004, H-006, H-007, H-009, H-010) no bloquean un despliegue a QA, pero deben quedar en el backlog de remediación con dueño y fecha antes de PRD. Las autoevaluaciones del proveedor en `docs/audits/` deben tratarse como material de referencia del proveedor, no como sustituto de esta auditoría ni de las firmas de aprobación de excepciones pendientes (`docs/05-Exceptions.md`): las definiciones válidas para esta entrega son las de Infraestructura MOA, no las que documenta el proveedor.

Esta es la **primera auditoría de MOA** sobre este repositorio; los IDs H-001..H-010 y C-001..C-005 quedan establecidos como referencia estable para toda re-auditoría futura.